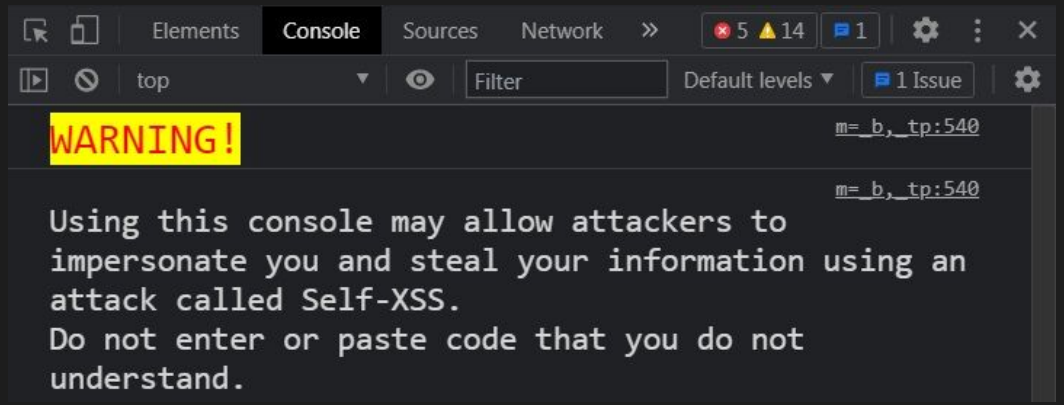
XSS Chain Reaction

Self-XSS

Alexis Savard

Why Self-XSS is rarely exploited

- Self-XSS is often dismissed as low-risk since it requires tricking victims into running malicious scripts themselves. However, this view is changing as more advanced exploitation methods emerge, highlighting its potential as a direct attack vector.



How to exploit Self-XSS (Option 1)

Option 1

On your server, create a Cross-Site Request Forgery (CSRF) that automatically logs the victim into the attacker's account. Use redirection parameters to send the victim to the page where the self-XSS is located (or open a new window). The self-XSS should perform the following actions:

- Create an iframe that takes up the entire window and insert a URL so that the iframe displays the login page. (You might need to hit the logout endpoint first.)
- Let the user log in, and voila!

Since the iframe and the webpage running the iframe have the same origin (and considering that iframes from the same origin are allowed), you should be able to fetch any information from the iframe during the period the user is using it. This means that if the user logs in, you can use a keylogger to retrieve the information typed. Additionally, you can fetch any information on the HTML page rendered in the iframe (such as API keys, CSRF tokens, etc.).

How to exploit Self-XSS (Option 2)

Option 2

On your server, create a **Cross-Site Request Forgery (CSRF) that automatically logs the victim into the attacker's account**. Use redirection parameters to send the victim to the page where the self-XSS is located. The self-XSS should perform the following actions:

- Capture the attacker's cookies.
- Save the cookies to local storage.
- Clear all cookies to log out the admin upon page refresh. (For HTTP-only cookies, use a Cookie Bomb.)
- Set the attacker's cookie with a specific path, such as /index.php (preferably where the self-XSS is located), ensuring the cookie takes precedence over others due to its specificity.
- When the admin logs back in and visits /index.php, the application will use the attacker's cookies for the session.
- Finally, redirect the victim to the login page to re-authenticate. (Include redirection parameters to deploy the self-XSS immediately.

Accessing /index.php:

- Upon logging in, the admin accesses /index.php, loading the page with the attacker's cookies.
- The self-XSS script executes again, with a condition such as checking for a cookie named admin.
- The self-XSS script exfiltrates all cookies, both the attacker's and the admin's.

Demo

Script

Blog